

11 Mo' Fuzzing

Jonathan Knudsen

jonathan.knudsen@duke.edu

Fall 2019

The idea for this assignment is to run a generational fuzzer (Peach) on a deliberately vulnerable server application. It's more fiddly than I expected. Give yourself plenty of time and ask questions when you get stuck.

Run vulnserver

This is deliberately vulnerable software. Do not run on any system that you don't mind being compromised. You'll set up a firewall to disallow outside connections, but still...

You can do this on Windows if you really want, but here is how you can do it on Linux.

There is a compatibility layer called `wine` that allows Windows executables to run on Linux. Install it like this:

```
sudo apt install -y wine64
```

Get `vulnserver` like this:

```
git clone https://github.com/stephenbradshaw/vulnserver.git
```

Set up the firewall so `vulnserver` cannot be accessed from the outside:

```
sudo ufw deny 9999
```

Then you can run `vulnserver` like this:

```
wine vulnserver.exe
```

Once it's running, in another window, you can interact with it by connecting on its default port, 9999:

```
nc vm-11732.vm.duke.edu 9999
```

Try typing some commands to get used to how it works. Hit Ctrl-C to exit.

Install Peach

Start here and follow the instructions for installing:

<https://www.peach.tech/resources/peachcommunity/>

You probably have to add Peach to your PATH, something like this:

```
export PATH=~/.Applications/peach:${PATH}
```

Read

Read the whole thing first.

<http://www.rockfishsec.com/2014/01/fuzzing-vulnserver-with-peach-3.html>

Now use the Peach “pit” (the XML file) as a starting point to fuzz your own vulnserver.

Fuzz

You can run Peach on your Peach pit like this:

```
peach vulnserver.xml TestHTER
```

Configure your Peach pit so that you can deliver fuzzed HTER commands to vulnserver.

There are a few different ways you can configure your fuzzing. No matter how you do it, you should be able to kill vulnserver.

You might find the *samples* directory in Peach to be useful, although I was not able to get LinuxCrashMonitor working no matter what.

Submit

Submit the following items:

1. Your Peach pit file (the XML configuration file).
2. The command or commands you use to run Peach.
3. The Peach *Logs* directory. Don't give me everything; just zip up and submit the directory for the run that shows at least one failure.